

тема: Анализ на сигурността на публични Wi-Fi мрежи: Опасности и мерки за защита

Съдържание

1. Резюме
2. Въведение
3. Основи на 802.11 и модел на заплахите в публични Wi-Fi мрежи
4. Типични атаки и уязвимости в публични Wi-Fi
 - 4.1. Пасивно подслушване в отворени мрежи (Open Wi-Fi)
 - 4.2. „Evil Twin“ и SSID Confusion (CVE-2023-52424)
 - 4.3. Man-in-the-Middle (MITM): ARP spoofing, DNS spoofing, SSL-stripping
 - 4.4. Captive портали – рискове за поверителност и сигурност
 - 4.5. Хищнически точки за достъп и „free Wi-Fi“ фишинг
 - 4.6. Проследяване чрез probe requests и метаданни
5. Оценка на риска и реалистичност на заплахите през 2025 г. (ролята на HTTPS, OWE/Enhanced Open и WPA3)
6. Мерки за защита – насоки за крайни потребители
7. Мерки за защита – насоки за оператори/администратори на публични мрежи
8. Правни и организационни аспекти (EC/GDPR, логване, информирано съгласие)
9. Практически чеклист (обобщение)
10. Заключение
11. Използвана литература (източници)

1. Резюме

Публичните Wi-Fi мрежи са съществена част от съвременната свързаност, но остават едни от най-рисковите комуникационни среди. Разширяването на безжичния достъп в градски зони, кафенета, университети, транспортни хъбове и хотели създава условия, в които всеки клиент се намира в обща мрежа с потенциално голям брой непознати устройства. Макар уебът да премина масово към криптирани протоколи като HTTPS/TLS, редица атаки все още са напълно приложими – включително подслушване на некриптиран трафик, пробиви чрез ARP/DNS spoofing, създаване на измамни точки за достъп и компрометиране на captive портали.

В последните години се появиха и нови атаки, които не разчитат на слабости в криптографията, а на поведенчески характеристики на клиентите. Така например уязвимостта SSID Confusion (CVE-2023-52424) показва, че дори съвременни устройства могат да бъдат подмамени да се свържат към фалшива мрежа, ако тя внимателно имитира параметрите на реалната. Това води до успешни атаки тип Man-in-the-Middle дори когато жертвата не подозира опасност.

В тази курсова работа разглеждам подробно архитектурата на публичните Wi-Fi мрежи, специфичните заплахи, оценка на риска през 2025 г., както и детайлни технически и организационни мерки за защита. Анализът показва, че безопасното използване на публичен Wi-Fi е напълно възможно, но изисква съзнателно поведение, актуални устройства и правилна конфигурация от страна на операторите.

2. Въведение

Публичните безжични мрежи (в кафенета, хотели, летища, кампуси и градски горещи точки) често са първи избор за свързване в движение. За разлика от корпоративните WLAN, при публичните мрежи доверието между клиента и инфраструктурата е ниско: мрежите са отворени или споделят общи ключове, устройствата са хетерогенни, а средата – непредсказуема. Тази комбинация създава уникален модел на заплахите.

Въпреки че криптирането на приложно ниво (HTTPS/TLS) значително повиши базовата сигурност, множество атаки остават възможни, особено когато се комбинират социално инженерство, уязвими конфигурации и стари протоколи (WEP/WPA-TKIP) или нефункционална проверка на сертификати.

3. Основи на 802.11 и модел на заплахите в публични Wi-Fi мрежи

IEEE 802.11 е стандартът, който дефинира безжичната комуникация, включително начина, по който точките за достъп (AP) и клиентите обменят management кадри, реализират връзка и криптират трафика. В публични среди се срещат множество варианти на конфигурации, но най-често те попадат в три категории:

- **Отворени Wi-Fi мрежи**, при които липсва криптиране на ниво връзка. При тях всяко устройство в обхвата може да наблюдава broadcast и unicast трафик, освен ако не е защитен чрез TLS.
- **Мрежи със споделена парола (WPA2-Personal)** – често използвани в кафенета и хотели. Макар да осигуряват базово криптиране, всички клиенти споделят един и същ ключ, което позволява пасивно дешифриране на трафик, ако атакуващият е присъствал по време на установяването на връзката.
- **Съвременни конфигурации (WPA3, OWE/Enhanced Open)** – предоставят индивидуално криптиране на връзката и защитени management кадри (PMF), което значително повишава сигурността.

Съществена част от модела на заплахите идва от начина, по който устройствата търсят мрежи. Клиентите периодично изпращат т.нар. **probe requests**, които разкриват списък от предварително запомнени SSID-и. Това позволява на атакуващи да създадат rogue AP, който се представя като предпочитана от клиента мрежа.

Управлението на трафика в публични Wi-Fi мрежи често включва captive портали, които пренасочват всяка заявка към страница за приемане на условия или регистрация. Този механизъм е удобен за администраторите, но поставя предизвикателства към потребителите и често нарушава нормалното TLS поведение.

4. Типични атаки и уязвимости в публични Wi-Fi. Типични атаки и уязвимости в публични Wi-Fi



4.1. Пасивно подслушване в отворени мрежи

В отворени (unencrypted) мрежи целият не-TLS трафик е видим на слой 2. Макар днес голяма част от уеба да използва HTTPS, остава експозиция за незашифровани протоколи (POP/IMAP без TLS, HTTP), метаданни (DNS, SNI при TLS<1.3) и за страници с неправилна конфигурация на HSTS.

4.2. „Evil Twin“ и SSID Confusion (CVE-2023-52424)

Класическият **evil twin** симулира SSID/портал на легитимна мрежа, принуждавайки клиента да се асоциира към нападателя. През 2024 г. е описана атака **SSID Confusion (CVE-2023-52424)**, която показва как клиенти могат да бъдат подмамени да се свържат към „погрешна“ мрежа с идентичен SSID/сходни параметри, заобикаляйки очакванията на потребителя.

4.3. MITM: ARP spoofing, DNS spoofing, SSL-stripping

На споделени broadcast домейни, **ARP spoofing/poisoning** позволява вмъкване по средата и пренасочване на трафика през нападателя. Комбинации с **DNS spoofing** и

SSL-stripping (понижаване на HTTPS към HTTP, когато липсва HSTS) отварят път към кражба на сесии и инжекции.

4.4. Captive портали – рискове

Порталите често изискват HTTP изключения преди достъп до интернет, блокират/инжектират трафик и събират лични данни (имейл/телефон/социални профили). Те могат да нарушават добри практики за TLS, да прекъсват автоматичното обновяване и да увеличат повърхността за фишинг.

4.5. Хищнически точки за достъп и „free Wi-Fi“ фишинг

Нападателите създават Wi-Fi с имена, наподобяващи „Airport-Free-WiFi“, примамват жертви и чрез captive страници/SSL-stripping събират пароли/картови данни.

4.6. Проследяване чрез probe requests

Дори без асоцииране устройствата излъчват probe заявки, които издават предварително познати SSID-и и метаданни, позволявайки **проследяване** във физическото пространство и профилиране.

5. Оценка на риска

Оценката на риска при публичните Wi-Fi мрежи се променя динамично. С преминаването към TLS 1.3, задължителното HTTPS при големите платформи и въвеждането на механизми като HSTS, класическото пасивно подслушване става по-трудно. Въпреки това няколко категории атаки остават актуални:

- **Атаки на слой 2** – ARP spoofing, DHCP spoofing и rogue AP продължават да бъдат ефективни, особено в мрежи без клиентска изолация.
- **Манипулация на DNS** – дори когато трафикът е криптиран, подмяната на DNS от локален нападател може да пренасочи жертвата към фалшиви домейни. Това е особено ефективно, ако не се използват DoH/DoT.
- **Слабости в captive портали** – често прекъсват нормалните TLS механизми, което излага потребителите на фишинг, HTTPS downgrade и non-secure redirects.

- **Нововъзникващи атаки** – SSID Confusion и подобни техники показват, че проблемите не са само в криптирането, а и в логиката на автоматичното свързване.

Въпреки подобренията, реалният риск за средния потребител остава осезаем, особено при използване на неконфигурирани устройства, остарели операционни системи или несигурни приложения.

6. Мерки за защита – насоки за крайни потребители.

1. **Предпочитайте мобилен интернет** за чувствителни операции (банкиране, работа).
2. **Използвайте VPN** при достъп до служебни системи или когато имате съмнение за средата.
3. **Проверявайте HTTPS:** търсете заключето/валидния домейн; избягвайте въвеждане на пароли в HTTP страници; активирайте разширения за принудително HTTPS, когато е приложимо.
4. **Деактивирайте автоматично присъединяване (auto-join)** към публични SSID-и; „Забравяйте“ мрежите след ползване.
5. **Използвайте MFA** и мениджър на пароли; не повтаряйте пароли.
6. **Актуализирайте ОС/браузър/клиент;** използвайте антивирус и защитна стена.
7. **Изолирайте споделянето:** изключете споделяне на файлове/принтери; активирайте „Public network“ профил (Windows/macOS/Unix).
8. **Внимавайте с captive портали:** въвеждайте минимални данни; избягвайте логин чрез социални профили; проверявайте URL на портала.
9. **Проверявайте SSID** с персонала и предпочитайте известни доставчици; избягвайте „Free-WiFi-No-Password“ без влагодател.
10. **Използвайте DoH/DoT** ако е налично; активирайте Private Relay/вграден VPN при съвместими устройства.

7. Мерки за защита – насоки за оператори

1. **Предпочитайте WPA3 (Personal/Enterprise) и Enhanced Open (OWE)** за безпаролни зони; активирайте **PMF (802.11w)**.
2. **Клиентска изолация (AP isolation) и LAN сегментация**; защитени VLAN-и; забраняване на L2 междуклиентска комуникация.
3. **DNS защита**: защитени резолвери, филтриране на зловредни домейни; поддръжка на DoH/DoT.
4. **Минимизиране на captive портал рисковете**: използвайте HTTPS-портали, минимален сбор на данни, прозрачни политики; избягвайте инжектиране на скриптове.
5. **WIPS/IDS** за откриване на rogue/evil twin AP; мониторинг на ARP/DHCP аномалии.
6. **Премахване на стари протоколи** (WEP, WPA-TKIP), забрана на слаби шифри; редовни актуализации на firmware.
7. **Разделяне на гост/служебен трафик**; Zero-trust достъп, допълнителна автентикация (802.1X/Enterprise) където е приложимо.
8. **Информирание на потребителите**: видими указания за сигурна употреба; лесен достъп до правила/политика за лични данни (GDPR).

8. Правни и организационни аспекти

Операторите в ЕС следва да съблюдават принципите на **GDPR** при обработка на лични данни (регистрации през портали, логове), да определят цели, срокове на съхранение и правно основание, и да осигурят прозрачност. Събирането на излишни данни (напр. задължителни социални профили) следва да се избягва.

9. Практически чеклист (обобщение)

За потребители: VPN при съмнение; без авто-join; проверка на SSID; само HTTPS; MFA; актуализации; изключено споделяне; забравяне на мрежата след ползване.

За оператори: WPA3/OWE + PMF; изолация между клиенти; WIPS/IDS; модерни DNS; минимален и защитен captive портал; редовни актуализации; ясна политика за лични данни.

10. Заключение

Сигурността на публичните Wi-Fi мрежи продължава да бъде важна и многопластова тема, която изисква внимание както от страна на потребителите, така и от страна на операторите. Макар развитието на технологии като WPA3, OWE и задължителното HTTPS да подобряват значително защитата, те не елиминират всички рискове.

Публичните мрежи остават среда, в която всеки клиент споделя ефирното пространство с потенциални атакуващи, а механизмите за удостоверяване и доверие често са ограничени.

Разгледаните в тази курсова работа атаки – от класически MITM техники като ARP и DNS spoofing до съвременни методи като SSID Confusion – показват, че дори модерните устройства могат да бъдат компрометирани, ако липсват адекватни механизми за проверка на мрежата. Особено критични остават случаи, в които потребителят се доверява на мрежи с привидно познато име или използва устройства, които автоматично се свързват към запомнени SSID-и без допълнителна проверка.

Анализът показва, че добрите практики могат значително да намалят риска. За потребителите най-ефективни остават простите стъпки – изключване на автоматично свързване, внимателно наблюдение на HTTPS сертификати, използване на VPN при нужда, редовни обновления на устройства и ограничаване на споделянето. От своя страна операторите имат ключова роля в създаването на сигурна среда чрез внедряване на WPA3, PMF, клиентска изолация, надеждни DNS механизми и прозрачни политики за лични данни.

Въпреки увеличаващата се сложност на нападателските техники, балансът между удобство и сигурност може да бъде постигнат. Когато техническите мерки се комбинират със съзнателно потребителско поведение, публичните Wi-Fi мрежи могат да бъдат използвани безопасно и ефективно дори в среди с голяма натовареност.

Очаква се с навлизането на Wi-Fi 7 и по-широкото разпространение на усъвършенствани криптографски протоколи допълнително да се намалят рисковете, но

фундаменталните принципи – проверка на доверие, ограничаване на повърхността за атаки и добра информираност – ще останат решаващи.

11. Използвана литература (източници)

[1] NIST SP 800-153: Guidelines for Securing WLANs. National Institute of Standards and Technology. <https://csrc.nist.gov/pubs/sp/800/153/final>

[2] NCSC (UK). Connecting Securely – Micro Exercise & Guidance.
<https://www.ncsc.gov.uk/files/connecting-securely-micro-exercise.pdf> ;
<https://www.ncsc.gov.uk/section/exercise-in-a-box/connecting-securely>

[3] EFF. Why Public Wi-Fi is a Lot Safer Than You Think.
<https://www.eff.org/deeplinks/2020/01/why-public-wi-fi-lot-safer-you-think>

[4] KeepnNetLabs: Tips for using public Wi-Fi.
<https://keepnetlabs.com/blog/how-to-use-public-wi-fi-safely>

[5] OWASP. Manipulator-in-the-Middle (MITM) Attack. https://owasp.org/www-community/attacks/Manipulator-in-the-middle_attack

[6] Wikipedia. ARP Spoofing. https://en.wikipedia.org/wiki/ARP_spoofing

[7] Gollier, H., Vanhoef, M. (2024). SSID Confusion: Making Wi-Fi Clients Connect to the Wrong Network. WiSec/NDSS preprint. <https://papers.mathyvanhoef.com/wisec2024.pdf>

[8] Wiz.io. CVE-2023-52424: Impact, Exploitability, and Mitigations.
<https://www.wiz.io/vulnerability-database/cve/cve-2023-52424>

[9] EFF. How Captive Portals Interfere With Wireless Security and Privacy.
<https://www.eff.org/deeplinks/2017/08/how-captive-portals-interfere-wireless-security-and-privacy>

[10] IBM. What is a Man-in-the-Middle (MITM) Attack?
<https://www.ibm.com/think/topics/man-in-the-middle>

[11] Wi-Fi Alliance / WPA3 & Enhanced Open (OWE) – преглед (вторични обяснения). TP-Link обзор: <https://www.tp-link.com/cl/wpa3/> ; Cisco Meraki: WPA3 Encryption and

Configuration Guide (2025). https://documentation.meraki.com/MR/Wi-Fi_Basics_and_Best_Practices/WPA3_Encryption_and_Configuration_Guide

[12] Fortinet. MITM Attack – понятие и примеры.

<https://www.fortinet.com/resources/cyberglossary/man-in-the-middle-attack>

[13] ENISA. Cyber Hygiene – насоки. <https://www.enisa.europa.eu/topics/cyber-hygiene>